GRC Incident Report — Simulated Brute-Force Attack Detected & Contained by SIEM Pipeline

Document ID	GRC-IR-2026-001	**Version**	1.0
Classification	INTERNAL — Controlled Simulation Exercise	**Status**	Closed — No compromise
Author	Aryan Upadhyay, SOC Analyst (trainee)	**Date**	2026-11-02
Environment	Wazuh 4.14.7 SIEM lab (VirtualBox) — non-production	**Review**	Open peer review via GitHub Issues

1. Executive Summary

On 28 September 2026, a simulated brute-force attack was detected against a Windows 11 endpoint ("victim", agent ID 006) in a controlled SIEM laboratory. Repeated failed authentication attempts triggered the Windows account-lockout control (Security Event 4740), and the Wazuh SIEM raised a level-9 alert (rule 60115) mapped to MITRE ATT&CK **T1110 — Brute Force**. The alert was automatically delivered to the analyst notification channel (custom e-mail integration) within one minute of detection. No unauthorized access succeeded; the incident is classified as **contained with zero impact** to confidentiality, integrity, or availability. This report documents the detection, the technical response, and — critically — the **governance, risk, and compliance (GRC) value** of the monitoring pipeline that made the detection possible.

2. Scope & Affected Assets

Asset	Role	Identifier
Windows 11 Enterprise endpoint	Affected asset / log source	Agent 006, 192.168.75.4
Wazuh manager + dashboard	SIEM / log aggregation	wazuh-server, 192.168.75.5
Custom Python integration	Alert notification channel	/var/ossec/integrations/custom-email.py
Isolated lab segment	Network scope	192.168.75.0/24 (host-only) + NAT egress

3. Technical Response — Detection & Analysis

Time (server)	Event
12:06–12:12	Repeated failed logon attempts against a local account (simulated attack)
12:12:31	Windows Security Event 4740 (account lockout) generated on the endpoint
12:12:31	Wazuh rule 60115 (level 9) fires; mapped to MITRE ATT&CK T1110, tactic Credential Access (TA0006)
12:12–12:13	Custom integration delivers alert e-mail (Mailtrap sandbox); analyst notified
~12:15	Analyst validates lockout message and alert context; confirms no successful logon
~12:20	Incident classified contained; account lockout acted as automatic containment

Analysis. The burst of authentication failures preceding the lockout is consistent with password-guessing (T1110). The lockout control prevented compromise, while SIEM correlation converted a raw Windows event into an actionable, timestamped, MITRE-mapped alert. Mean time to acknowledge (MTTA): **under 5 minutes**, enabled by automated notification.

4. Impact Assessment

- Confidentiality / Integrity / Availability: **no impact**.
- Severity: **Low** (attempted, contained). Risk realized: none. Risk demonstrated: credential-based attack surface.
- Control effectiveness: account-lockout policy and SIEM detection both operated as designed.

5. GRC & Compliance Value

This detection pipeline is not only a technical control — it is **compliance evidence**:

- **ISO/IEC 27001, Annex A.12.4 "Logging and monitoring"** (2013 numbering; renumbered **A.8.15 Logging / A.8.16 Monitoring** in the 2022 revision): continuous security-event collection (1,565 alerts indexed in 24 h), central log protection on the manager, and monitoring that produced this alert satisfy the control's intent.
- **EU NIS2 Directive (EU) 2022/2555, Art. 21(2)(b) incident handling and Art. 21(2)(g) cyber hygiene**: the pipeline proves the organization can detect, analyze, and document unauthorized-access attempts; the timestamped alert trail supports **Art. 23 reporting duties** (24 h early warning / 72 h notification) should a reportable incident occur.
- **NIST CSF 2.0, DE.CM (continuous monitoring) and RS.AN (analysis)**: rule-level alerting, MITRE mapping, and this report embody the Detect and Respond functions.
- **NIST SP 800-61r2**: this document follows the Detection & Analysis → Post-Incident documentation lifecycle.

Framework	Control	Evidence in this pipeline
ISO/IEC 27001 A.12.4 (2013) / A.8.15–16 (2022)	Logging & monitoring	Continuous Windows event-channel collection; central indexing; alerting
NIS2 Art. 21(2)(b),(g); Art. 23	Incident handling, hygiene, reporting	Detected & documented attempt; timestamped audit trail; notification channel
NIST CSF 2.0 DE.CM / RS.AN	Monitor; analyze	Rule 60115 → T1110 mapping; dashboards; MTTA < 5 min
CIS Controls v8, 8.2 / 8.5	Collect & retain audit logs	Agent-based collection; manager-side retention

6. Risk Treatment & Recommendations

- Enforce MFA / passwordless phasing (NIS2 Art. 21(2)(j)) to shrink T1110 exposure.
- Alert on a failed-logon threshold (e.g., 5 failures) *before* lockout, for earlier detection.
- Formalize log-retention periods and protect log integrity (ISO A.12.4.2).
- Synchronize clocks via NTP to guarantee log evidentiary value (ISO A.12.4.4).
- Extend coverage: RDP/SMB logon auditing (4625 burst rules) and Sysmon.
- Re-run this simulation quarterly as **control-testing evidence** for audits.

7. Lessons Learned

Automated notification reduced MTTA to minutes; the lockout control proved effective as both preventive and detective measure; and writing the incident in GRC format converted technical work into **audit-ready evidence** — the bridge between SOC operations and governance.

8. Approval

Role	Name	Date	Signature
Prepared by	Aryan Upadhyay	2026-11-02	
Reviewed by	(open peer review)		
Approved by			

Appendix A — Evidence: repository files wazuh-events-table.png, wazuh-dashboard-alerts.png, custom-email.py, README.md; alert references: Wazuh rule 60115, Windows Event 4740, MITRE ATT&CK T1110.
Disclaimer: controlled laboratory simulation; no production systems or real user data involved.